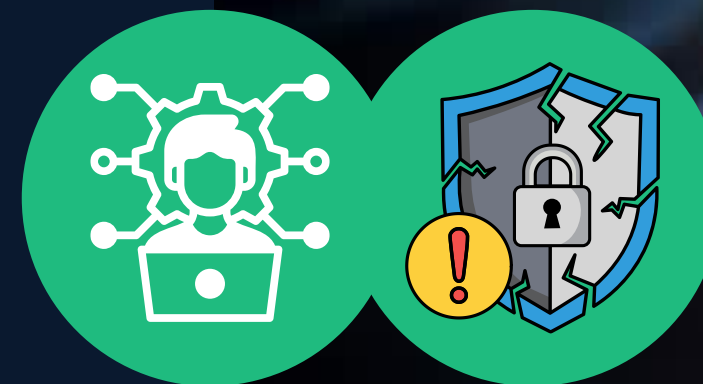


MULTIMEDIA UNIVERSITY, MALAYSIA

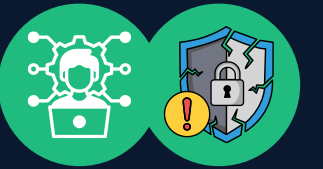
Network Protection Systems

ETHICAL HACKING AND PENETRATION TESTING
CCS6324 - 2530

Dr. Hafiz Adnan Hussain

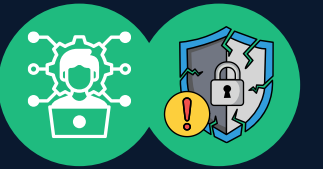


DISCLAIMER



- This course is designed to educate students on ethical hacking principles. The knowledge and techniques acquired must be used responsibly and not for any illegal or unauthorized activities.
- Each student is solely responsible for their actions.
- Do not investigate individuals, websites, servers or conduct any illegal activities on any system you do not have permission to analyze.
- The course content has been developed in good faith, drawing from the author's experience and reputable sources. While every effort has been made to ensure accuracy, the author does not guarantee absolute correctness. Students are encouraged to exercise discretion and actively engage in discussions by raising any questions or concerns during the course.

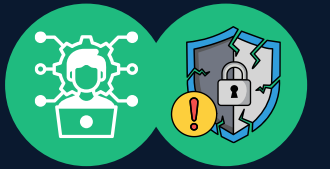
Learning Objectives



What You Will Learn?

- The role and architecture of network protection systems
- Configure and bypass common firewall implementations
- Understand IDS/IPS detection methodologies
- Deploy and analyze honeypot systems
- Assess security device limitations and misconfigurations
- Apply defense-in-depth principles in network security design

1: Network Protection System Overview



1.1 What is Network Protection Systems (NPS)?

Network Protection Systems are integrated collections of hardware, software, and configurations designed to:

- Protect network integrity, confidentiality, and availability
- Form defensive perimeters against cyber threats
- Implement layered security (Defense-in-Depth principle)
- Guard against unauthorized access and data disclosure

1.2 Defense-in-Depth Strategy

Rather than relying on a single security measure, organizations stack multiple protective layers:

User Access Layer



Application Layer (Web Application Firewalls (WAF))



Network Layer (Firewalls, IDS/IPS)



Infrastructure Layer (Switches, Routers)



Physical Layer (Data Center Security)

1.3 Why Penetration Testers Learn NPS

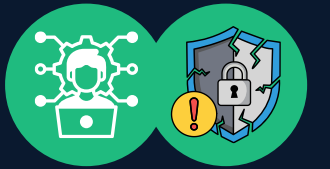
For Defenders:

- Design secure network architectures
- Identify misconfigurations and vulnerabilities
- Ensure regulatory compliance (GDPR, HIPAA, PCI-DSS)

For Ethical Hackers/Pentesters:

- Understand system limitations and weaknesses
- Develop effective evasion and bypass techniques
- Assess real security posture
- Create realistic penetration test scenarios
- Recommend security improvements

2: Core Components (CC)



These are some core components of NPS:

1. Routers
2. Switches
3. Firewalls
4. Intrusion Detection & Prevention Systems
5. Web Application Firewalls (WAF)
6. Honeypots
7. Security Information and Event Management (SIEM) & Network Access Control (NAC)

2: CC (1: Routers)



2.1 Role and Architecture

Routers operate at Layer 3 (Network Layer) of the OSI model:

- Forward IP packets between different networks
- Serve as the first line of defense for network segmentation
- Implement basic traffic filtering via Access Control Lists (ACLs)

2.2 Cisco Router Components

Component	Function	Security Relevance
IOS	Operating system	Firmware vulnerabilities
RAM	Routing tables, running config	Volatile; lost on reboot
NVRAM	Startup configuration	Persists across reboots
Flash Memory	Stores IOS image	Update/downgrade risk
ROM	Minimal IOS for boot	Boot security
Interfaces	Physical connections	Port security, isolation

2.3 Access Control Lists (ACLs)

Purpose: Filter traffic based on defined criteria, processed top-down (first match wins)

Standard IP ACLs (Limited Granularity):

```
access-list 1 deny 173.110.0.0 0.0.255.255
access-list 1 permit any
interface GigabitEthernet0/1
ip access-group 1 in
```

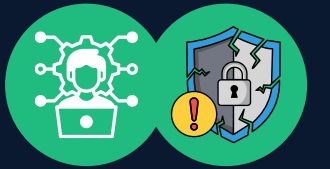
- Filters based on source IP only
- Less precise but simple

Extended IP ACLs (Fine-Grained Control):

```
access-list 101 permit tcp any host 192.168.1.100 eq 80
access-list 101 deny tcp any host 192.168.1.100 eq 23
access-list 101 permit ip any any
interface GigabitEthernet0/0
ip access-group 101 in
```

- Filters by source/destination IP, protocol, port
- More precise control

2: CC (1: Routers) (Cont'd)



2.4 Misconfigured ACL Bypass Example

Problem: Allowing all packets from source port 80 (web response):

```
access-list ALLOW_WEB permit tcp any any eq 80
```

Attack Scenario: Attacker sets source port to 80:

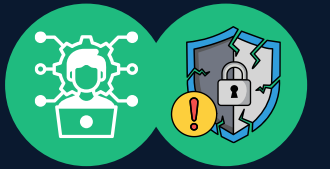
```
attacker → victim:xxxxx (with src port 80)
```

Firewall sees source port 80 and allows it, bypassing intended restrictions.

2.5 Router Security Best Practices (2025)

- **Credentials:** Change default admin/enable passwords; use strong, unique credentials
- **Services:** Disable HTTP/Telnet management; enforce SSH v2 only
- **Firmware:** Keep IOS patched and updated
- **Management Access:** Restrict via ACLs; use TACACS+ or RADIUS authentication
- **Anti-Spoofing:** Implement Unicast Reverse Path Forwarding (uRPF) or BCP38 filters
- **Logging:** Enable syslog and send to centralized SIEM
- **Routing Protocols:** Secure OSPF/BGP with MD5 authentication
- **Control Plane Policing (CoPP):** Protect router CPU from DoS attacks

3: CC (2: Switches)



3.1 Role and Architecture

Switches operate at Layer 2 (Data Link Layer):

- Forward Ethernet frames within LANs based on MAC addresses
- Build Content Addressable Memory (CAM) tables for forwarding
- Control internal network security and segmentation

3.2 Key Protection Methods

Port Security:

```
interface GigabitEthernet0/1
  switchport port-security
  switchport port-security maximum 1
  switchport port-security mac-address sticky
  switchport port-security violation shutdown
```

- Limits MAC addresses per port
- Actions on violation: shutdown, restrict, or alert

VLANs (Virtual Local Area Networks):

```
vlan 10 name HR_VLAN
interface GigabitEthernet0/2
  switchport access vlan 10
```

- Logically segment LANs into broadcast domains
- Isolate traffic between departments
- Private VLANs (PVLANS) provide further isolation

3.2 Key Protection Methods (Cont'd)

DHCP Snooping:

- Filters DHCP messages from untrusted sources
- Prevents rogue DHCP servers from assigning malicious configurations
- Builds and maintains binding tables

Dynamic ARP Inspection (DAI):

- Validates ARP packets using DHCP binding tables
- Prevents ARP poisoning and Man-in-the-Middle attacks
- Drops spoofed ARP messages

Spanning Tree Protocol (STP) Security:

- BPDU Guard: Disables ports receiving unexpected BPDUs
- Root Guard: Prevents unauthorized switches from becoming STP root

3.3 Switch Security Best Practices

- Disable unused ports (unused = attack surface)
- Change default credentials; use strong passwords
- Use SSH for management access
- Create a dedicated management VLAN
- Implement 802.1X port-based access control
- Enable logging and send to SIEM
- Keep firmware updated

4: CC (3: Firewalls)



4.1 Firewall Overview

Definition: Hardware or software that monitors and controls incoming/outgoing traffic based on security policies.

Purpose:

- Create a barrier between trusted (internal) and untrusted (external) networks
- Segment internal networks
- Enforce organizational security policies

4.2 Firewall Types and Technologies

By Data Filtering Method:

1- Packet Filtering (Stateless)

- Examines packet headers only (source/destination IP, port, protocol)
- Fast but limited intelligence
- Can be bypassed with spoofed packets

2- Stateful Packet Inspection (SPI)

- Maintains the state table of active connections
- Allows return traffic from established connections
- More intelligent than stateless filtering
- Example: Allow web server response (port 80) only if the internal client initiated the request

3- Application Layer / Proxy Firewall

- Inspects content for specific protocols (HTTP, FTP, SMTP)
- Understands application semantics
- Can detect protocol violations and attacks
- Higher CPU overhead

4.2 Firewall Types and Technologies (Cont'd)

By Form Factor:

Hardware Firewalls	Software Firewalls
Higher throughput	Host-level protection
Centralized management	Fine-grained user policies
Limited by hardware	OS-dependent
Usually filter inbound only	Filter inbound/outbound

4.3 Firewall Technologies

Network Address Translation (NAT):

- Maps private IP addresses to public external IPs
- Hides internal network structure
- Provides basic stateful inspection

Port Address Translation (PAT):

- Many-to-one NAT using different ports
- Example: Multiple internal IPs (192.168.1.100, 192.168.1.101) → Single public IP (147.144.20.1) with different ports

4: CC (3: Firewalls) (Cont'd)



4.4 Next-Generation Firewalls (NGFWs)

Modern firewalls include advanced capabilities:

Capability	Purpose
Deep Packet Inspection (DPI)	Inspect application layer content
Integrated IPS	Block detected intrusions
Application Awareness	Control apps regardless of port
User Identity Awareness	Policy enforcement via AD integration
Threat Intelligence Feeds	Real-time threat data
SSL/TLS Decryption	Inspect encrypted traffic
Sandboxing	Detonate suspicious files safely
AI/ML Detection	Anomaly-based threat detection

Leading NGFW Vendors (2025): Palo Alto Networks, Fortinet FortiGate, Cisco Secure Firewall

4.5 Demilitarized Zone (DMZ)

Architecture:

Internet ↔ [Firewall] ↔ DMZ (Public Services) ↔ [Firewall] ↔ Internal Network

Purpose:

- Perimeter network between the Internet and the internal network
- Hosts public-facing services (web, email, DNS servers)
- If the DMZ is compromised, the second firewall protects the internal network
- Implements defense-in-depth

4.6 Host-Based Firewalls

Windows Defender Firewall:

Manage via netsh (command line)

```
netsh advfirewall firewall add rule name="Allow Web"
dir=in action=allow protocol=TCP localport=80
```

Three profiles: Domain, Private, Public

```
netsh advfirewall show domainprofile
```

Linux Firewall (Netfilter Framework):

Tools available:

- iptables (legacy, widely used)
- nftables (modern replacement, more flexible)
- firewalld (higher-level abstraction)
- ufw (Uncomplicated Firewall, beginner-friendly)

4: CC (3: Firewalls) (Cont'd)



4.4 Next-Generation Firewalls (NGFWs)

Modern firewalls include advanced capabilities:

Capability	Purpose
Deep Packet Inspection (DPI)	Inspect application layer content
Integrated IPS	Block detected intrusions
Application Awareness	Control apps regardless of port
User Identity Awareness	Policy enforcement via AD integration
Threat Intelligence Feeds	Real-time threat data
SSL/TLS Decryption	Inspect encrypted traffic
Sandboxing	Detonate suspicious files safely
AI/ML Detection	Anomaly-based threat detection

Leading NGFW Vendors (2025): Palo Alto Networks, Fortinet FortiGate, Cisco Secure Firewall

4.5 Demilitarized Zone (DMZ)

Architecture:

Internet ↔ [Firewall] ↔ DMZ (Public Services) ↔ [Firewall] ↔ Internal Network

Purpose:

- Perimeter network between the Internet and the internal network
- Hosts public-facing services (web, email, DNS servers)
- If the DMZ is compromised, the second firewall protects the internal network
- Implements defense-in-depth

4.6 Host-Based Firewalls

Windows Defender Firewall:

Manage via netsh (command line)
netsh advfirewall firewall add rule name="Allow Web" dir=in
action=allow protocol=TCP localport=80

Three profiles: Domain, Private, Public
netsh advfirewall show domainprofile

Linux Firewall (Netfilter Framework):

Tools available:

- sudo iptables -A INPUT -p tcp --dport 22 -j ACCEPT (legacy, widely used)
- sudo nft add rule inet filter input tcp dport 22 accept (modern replacement, more flexible)
- sudo ufw allow ssh && sudo ufw enable (Uncomplicated Firewall, beginner-friendly)

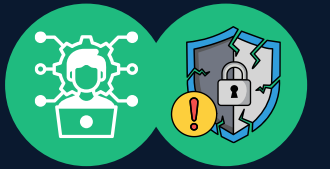
View rules

```
sudo iptables -L -n  
sudo nft list ruleset  
sudo ufw status
```

Linux Kernel Hooks (Netfilter):

Incoming Packet → NF_IP_PRE_ROUTING (modify before routing decision) → [Routing Decision] → NF_IP_LOCAL_IN (destined for this host) | NF_IP_FORWARD (forward to another host) → Application Processing → NF_IP_LOCAL_OUT (traffic generated locally) → NF_IP_POST_ROUTING (final modifications) → Outgoing Packet

4: CC (3: Firewalls) (Cont'd)



4.7 Firewall Bypassing Techniques (Pentester Knowledge)

Source Port Spoofing:

- Send traffic from the allowed source port (e.g., 80, 443)

Fragmentation:

- Break packets into fragments to evade signature-based detection
- Stateful firewalls reassemble before inspection

Protocol Tunneling:

- Encapsulate forbidden protocols inside allowed ones (SSH over HTTP)

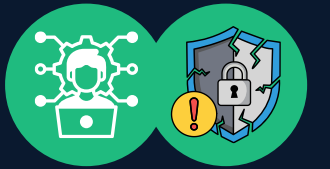
ACL Logic Errors:

- Exploit rule ordering or contradictory rules
- Example: Rule 1 allows traffic, Rule 10 denies (Rule 1 processed first)

Timing-Based Evasion:

- Distribute attack traffic over time to evade rate-limiting

5: CC (4: Intrusion Detection & Prevention Systems)



5.1 IDS vs IPS

Intrusion Detection System (IDS):

- Monitors network traffic for malicious activity
- Sends alerts to administrators
- Passive system (doesn't block, only notifies)
- Like a burglar alarm

Intrusion Prevention System (IPS):

- Actively blocks detected intrusions
- Can interwork with routers/firewalls to block traffic
- Can drop packets in-line
- Like a security guard stopping the burglar

5.2 IDS/IPS Types

By Scope:

- NIDS/NIPS: Monitor traffic on network segments; good for overall visibility
- HIDS/HIPS: Monitor activity on individual hosts; excellent for critical servers

5.2 IDS/IPS Types (Cont'd)

By Detection Method:

- 1- Signature-Based (Pattern Matching)
 - Matches known attack patterns/exploits
 - Fast, low false positives for known threats
 - Misses unknown/zero-day attacks
 - Requires frequent signature updates
- 2- Anomaly-Based (Behavioral Analysis)
 - Establishes baseline of normal behavior
 - Detects deviations from baseline
 - Effective against zero-days and novel attacks
 - Higher false positives (legitimate unusual activity flagged)
- 3- Hybrid Approach
 - Combines signature and anomaly detection
 - Balances coverage and false positive rates

5.3 IDS/IPS Examples

Open Source:

- Snort: Rule-based, widely used in enterprises
- Suricata: Multi-threaded, supports Snort rules
- Zeek (formerly Bro): Network analysis and security monitoring
- Security Onion: Complete IDS/IPS distribution

Commercial:

- Cisco, Palo Alto Networks, Fortinet

5: CC (4: Intrusion Detection & Prevention Systems) (Cont'd)

5.4 Snort Rule Basics

```
alert tcp any any -> 192.168.1.0/24 80
(msg:"HTTP traffic detected"; sid:1000001;)
```

Structure:

```
[ACTION] [PROTOCOL] [SOURCE] [SOURCE_PORT] ->
[DESTINATION] [DEST_PORT] (options)
```

Common Actions: alert, drop, pass, reject

Options:

- msg: Description
- sid: Unique rule ID
- content: Search for specific strings
- pcre: Perl-compatible regular expressions
- threshold: Alert limiting
- classtype: Attack category

5.5 IDS Evasion Techniques

Encryption:

- Encrypted traffic bypasses content inspection
- IDS can only see encrypted blobs

Fragmentation:

- Split the attack payload across multiple packets
- IDS may not reassemble and detect

Timing-Based Evasion:

- Spread attack over time (slow scan)
- Evade rate-based detection

Protocol Anomalies:

- Send malformed packets
- IDS may reject while vulnerable service processes them

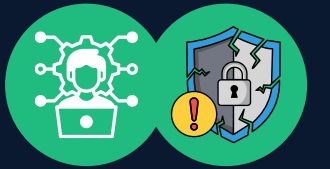
Polymorphic Payloads:

- Encode exploits to avoid signature matching
- Different encoding each attempt

5.6 AI/ML in IDS/IPS (2025 Advancements)

- **Improved Anomaly Detection:** Random Forest, Neural Networks, LSTM models
- **Adaptive Learning:** Reinforcement learning adjusts detection over time
- **Reduced False Positives:** Better contextual understanding
- **Zero-Day Detection:** Behavioral patterns catch unknown attacks

6: CC (5: Web Application Firewalls (WAF))



6.1 Purpose

Definition: A specialized firewall that filters, monitors, and blocks HTTP/HTTPS traffic to/from web applications.

Protection Against:

- SQL Injection (SQLi)
- Cross-Site Scripting (XSS)
- Cross-Site Request Forgery (CSRF)
- File Upload Vulnerabilities
- Command Injection
- Path Traversal
- DDoS attacks

6.2 WAF Deployment Modes

Reverse Proxy Mode:

Browser → **WAF** → **Web Server**

(WAF is a transparent proxy)

Inline Mode:

Browser → **Firewall** → **WAF** → **Web Server**

Out-of-Band/Detection Mode:

Traffic mirrored to WAF (no blocking capability)

6.3 Detection Methods

Negative Security (Blacklisting):

- Blocks known bad signatures
- Fast, low overhead
- Misses novel attack variants
- Example: Block requests containing union select

Positive Security (Whitelisting):

- Only allows known good patterns
- More secure but restrictive
- May block legitimate, unusual requests
- Requires careful tuning

6.4 WAF Examples

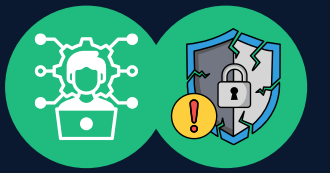
Open Source:

- ModSecurity: Industry standard, Apache/Nginx
- OWASP CRS: Core Rule Set for ModSecurity

Cloud/Commercial:

- AWS WAF
- Azure WAF
- Cloudflare
- Akamai

6: CC (5: Web Application Firewalls (WAF)) (Cont'd)



6.5 WAAP & API Security (2025 Evolution)

WAAP (Web Application and API Protection):

- Extends WAF capabilities to APIs
- APIs are rapidly becoming the primary attack surface
- Includes API schema validation, rate limiting per API

Key Features:

- Core WAF + API-specific protection
- Bot Management (distinguish good vs malicious bots)
- Layer 7 DDoS mitigation
- AI/ML threat detection

API Security Challenges:

- Shadow/zombie APIs (undocumented endpoints)
- API key exposure
- Broken access control in APIs
- Rate limiting abuse

6.6 WAF Bypass Techniques

Encoding Variations:

- URL encoding: `union%20select`
- Unicode encoding: `\u0075nion`
- Double encoding

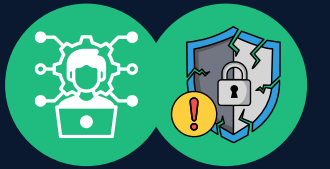
Polyglot Payloads:

- Payloads valid in multiple contexts

WAF Specific Knowledge:

- Some WAFs have known weaknesses
- Configuration errors (overly permissive rules)

7: CC (6: Honeypots)



7.1 Purpose

Honeypot: A decoy system intentionally vulnerable and designed to attract and trap attackers.

Benefits:

- Early Warning: Detect intrusions targeting non-production systems
- Threat Intelligence: Capture attacker tools, TTPs, malware samples
- Attribution: Gather data for law enforcement
- Distraction: Keep attackers occupied while defenders respond

7.2 Types of Honeypots (By Interaction Level)

1- Low-Interaction Honeypots

- Simulate services without a full OS
- Examples: Honeyd, Cowrie (SSH simulator)
- Lightweight, easy to deploy
- Limited data capture (doesn't fool sophisticated attackers)

2- High-Interaction Honeypots

- Real operating systems and services
- Full environment for attacker interaction
- Rich data collection
- More complex, higher risk if compromised
- Examples: Real Windows/Linux VMs configured as bait

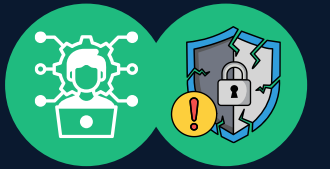
3- Honeynets

- Networks of honeypots
- Simulate entire target networks
- Monitor lateral movement and attacker progression

4- Honeytokens

- Fake data (credentials, files, API keys)
- Distributed throughout the network
- Alert if accessed by unauthorized users
- Excellent for detecting breaches

7: CC (6: Honeyd) (Cont'd)



7.3 Honeyd Deployment (Best Practices) 7.4 Examples

1- Isolation:

- Deploy in DMZ or separate VLAN
- Prevent lateral movement to production systems
- Use firewalls to restrict outbound connections

2- Realism:

- Deploy realistic services and data
- Include known vulnerabilities (older web server, unpatched OS)
- Make it an attractive target

3- Monitoring:

- Capture all traffic (pcap)
- Log all system activity
- Monitor for privilege escalation attempts
- Send alerts to SOC/SIEM

4- Automation & Analysis:

- Containerize honeypots (Docker, Kubernetes)
- Automate deployment and teardown
- AI/ML analysis of collected data
- SIEM integration for correlation

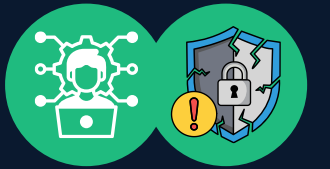
Honeyd: Low-interaction honeypot, simulates multiple services and OS fingerprints

Kippo/Cowrie: SSH honeypots, log attacker commands and sessions

Dionaea: Low-interaction honeypot, captures malware samples

Project Honey Pot: Web-based honeypot project that tracks email harvesting and spam

8: CC (7: SIEM & NAC)



8.1 SIEM (Security Information and Event Management)

Purpose: Centralized platform aggregating and analyzing security logs from all devices.

Functions:

- Log collection and aggregation
- Real-time correlation and analysis
- Alerting on suspicious patterns
- Incident response support
- Compliance reporting (GDPR, HIPAA, PCI-DSS)

Examples:

- Splunk
- IBM QRadar
- Elastic SIEM
- Microsoft Sentinel

Value for Pentesters:

- Understand detection capabilities
- Know what events trigger alerts
- Develop evasion techniques (cover tracks)
- Identify logging gaps

8.2 NAC (Network Access Control)

Purpose: Enforce security policies for devices/users accessing the network.

Ensures:

- Only authorized devices connect
- Devices are compliant (patches, antivirus current)
- Isolation of non-compliant devices

Examples:

- Cisco ISE (Identity Services Engine)
- Aruba ClearPass

8.3 VPN Concentrators

Purpose: Secure, encrypted tunnels for remote access

Security Features:

- Encryption (IPSec, TLS)
- User authentication
- Access control
- Logging and monitoring

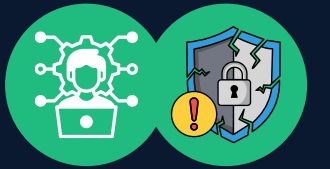
8.4 Web/Content Filtering

Purpose: Block access to malicious/inappropriate websites

Methods:

- URL category blocking (phishing, malware, adult sites)
- DNS filtering (resolve malicious domains to a sinkhole)
- SSL inspection (decrypt, inspect, re-encrypt traffic)

9: Practical Bypassing Scenarios



9.1 Firewall Bypass Scenario: Port Knocking

Some firewalls allow access after sequence of connection attempts to specific ports.

Attack:

Attacker sends SYN to port 1234, 5678, 9999 in sequence

→ Firewall sees pattern, opens port 22

→ Attacker connects to SSH

Mitigation: Implement time-based windows, randomize port sequence

9.2 IDS Evasion: Slow Scan

Normal port scan: 1000 ports/minute (detected)

Slow scan: 1 port/5 minutes (may evade rate-limiting)

9.3 WAF Bypass: Comment Injection

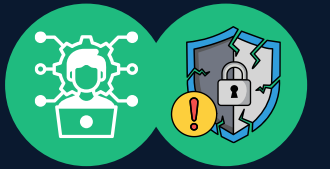
Original attack: union select password from users

WAF blocks: "union select"

Bypass: uni/*comment*/on sel/**/ect password from users

(If WAF doesn't handle comments properly)

10: Defense-in-Depth Integration



Complete Security Stack Example:

Perimeter:

- └ Firewall (NGFW)
- └ IDS/IPS (NIDS)
- └ WAF (web apps)

Internal Network:

- └ Host Firewalls
- └ HIDS/HIPS
- └ Honeypots

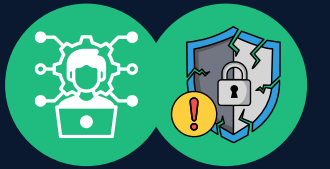
Visibility & Response:

- └ SIEM (centralized logging)
- └ NAC (device compliance)
- └ Threat Intelligence Feeds

Key Principle: No single technology provides complete protection. Layers work together:

- Firewall catches protocol violations
- IDS/IPS detects known exploits
- WAF stops web attacks
- Honeypots reveal new techniques
- SIEM correlates events for incident response

Key Takeaways For Pentesters



- **Understand Limitations:** Every security device has weaknesses
- **Configuration Matters:** Misconfigurations are the primary vulnerability
- **Layering Works:** Defense-in-depth significantly increases resistance
- **Detection vs Prevention:** Detection alone (IDS) is insufficient
- **Application Layer Critical:** Firewalls miss application-level attacks (WAF needed)
- **Logging Vital:** No logging = no evidence (SIEM essential)
- **Know Yourself:** Honeypots reveal attacker tools and techniques

REFERENCES



- Cisco IOS Configuration Guides
- NIST Cybersecurity Framework
- OWASP Top 10 Web Application Vulnerabilities
- CIS Benchmarks (Routers, Firewalls, Linux)
- OffSec Penetration Testing Playbook
- SANS Cyber Aces (Free tutorials)

Thank You

ANY QUESTIONS?

